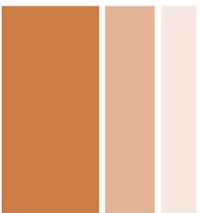


PLANIFICACIÓN Y PROGRAMA DE AUDITORÍA



U.D. AUDITORÍA INFORMÁTICA

SESION : 08

ING. CLAUDIA RUBIO JIMENEZ



NORMAS DE CONVIVENCIA

- ✓ Respetarse entre compañeros
- ✓ Trabajar con responsabilidad
- ✓ No está permitido jugar con los celulares, computadoras, escuchando música, viendo videos no relacionados a la sesión de aprendizaje.
- ✓ Está prohibido comer dentro y durante la sesión de clase.
- ✓ Ser puntuales en asistir a clases.
- ✓ Cuidar el monitor, CPU, teclado, mouse, cables de red, entre otros.



PROPÓSITO

Al finalizar la sesión, el estudiante organiza una auditoría informática en un programa coherente y ejecutable.

Identificar

Reconoce los componentes que deben definirse antes de ejecutar una auditoría.

Diseñar

Relaciona objetivos, alcance, criterios, recursos, cronograma y responsables.

Programar

Redacta procedimientos y selecciona técnicas para obtener evidencia suficiente.

Pregunta guía: ¿Qué podría salir mal si una auditoría comienza sin planificación?

¿Por qué planificar una auditoría informática?

IMPORTANCIA

- Permite saber qué se auditará, para qué, con qué criterios y dentro de qué límites.
- Ayuda a concentrar tiempo y esfuerzo en procesos, activos o riesgos relevantes.
- Reduce improvisaciones y facilita que el trabajo del equipo sea ordenado y trazable.
- Hace posible programar evidencias, entrevistas, pruebas y actividades de seguimiento.
- Genera una base clara para comparar lo planificado con lo realmente ejecutado.

Planificación vs. Programa de Auditoría

Planificación

Define la dirección de la auditoría: objetivos, alcance, criterios, riesgos, recursos, tiempos y responsables.

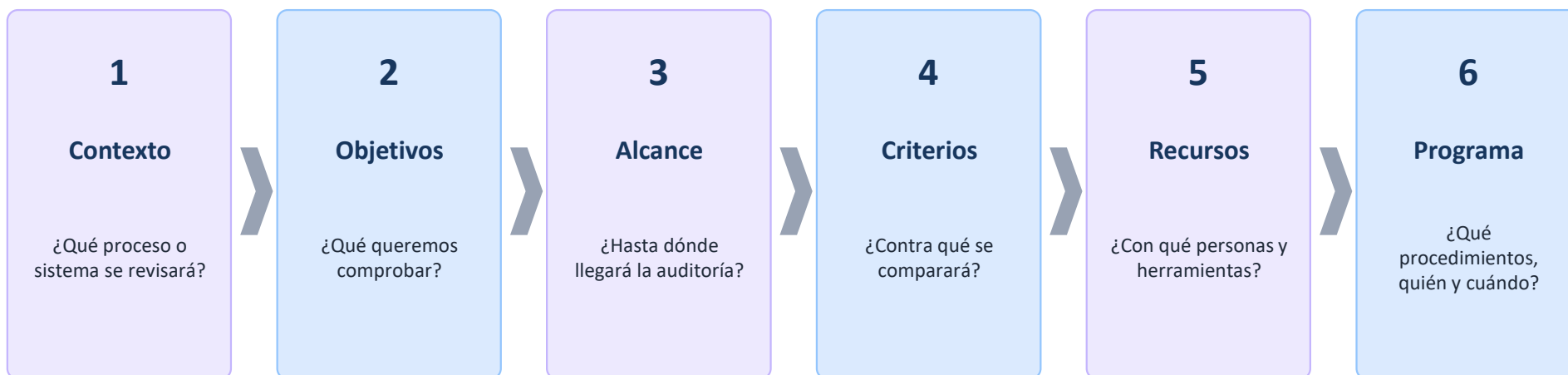


Programa de auditoría

Convierte la planificación en tareas verificables: qué procedimiento se hará, cómo, con qué evidencia, quién lo realizará y cuándo.

Ruta de planificación de una auditoría

Una secuencia lógica evita omisiones y facilita la supervisión.



Antes de programar pruebas, el auditor debe entender el proceso, sus riesgos y los criterios aplicables.

OBJETIVOS

- Expresan lo que la auditoría pretende determinar, evaluar o verificar.
- Deben ser claros, concretos y relacionados con el propósito de la auditoría.
- Conviene formularlos con verbos observables: verificar, evaluar, determinar, comprobar, revisar, identificar.
- Cada procedimiento del programa debe contribuir a responder uno o más objetivos.

1. Objetivos de Auditoría

Ejemplo

Verificar la gestión de accesos al sistema ERP.

Ejemplo

Evaluar si los respaldos cumplen la política interna.

Ejemplo

Determinar si los incidentes se registran y atienden oportunamente.

¿Cómo redactar buenos objetivos?

Demasiado amplio

“Revisar el sistema informático.”

Problema: no indica qué se verificará ni qué resultado se busca.

Más preciso

“Evaluar si los controles de acceso al ERP restringen los privilegios según las funciones asignadas.”

Ventaja: delimita el objeto de revisión y orienta los procedimientos.

Fórmula práctica

Verbo observable + objeto de revisión + condición o criterio de interés

2. Alcance de la Auditoría

ALCANCE

- Define los límites de la auditoría: procesos, áreas, sistemas, sedes, periodos, datos y controles incluidos.
- También debe dejar claro qué queda fuera del trabajo para evitar expectativas incorrectas.
- Debe ser suficiente para alcanzar los objetivos, pero manejable con los recursos disponibles.
- Ejemplo: "Gestión de accesos y respaldos del ERP de la sede principal, periodo enero–agosto 2026".

Incluye

ERP • accesos • respaldos • registros

Límite

Sede principal • 2026

Excluye

Desarrollo de software

CRITERIOS

Políticas internas

Políticas de seguridad, continuidad, contraseñas, respaldos, cambios, uso aceptable.

Procedimientos

Procedimientos operativos aprobados para registrar, autorizar, monitorear y responder.

Normas / contratos

Requisitos normativos, contractuales, acuerdos de servicio o buenas prácticas adoptadas.

3. Criterios de Auditoría

Los criterios responden a la pregunta:

¿Contra qué evidencia vamos a comparar lo observado?

RECURSOS

Humanos

Auditor líder, auditores, especialistas, responsables del área auditada.

Tecnológicos

Laptop, herramientas de análisis, acceso al sistema, almacenamiento seguro de evidencias.

Documentales

Políticas, procedimientos, inventarios, reportes, tickets, registros y diagramas.

Tiempo y presupuesto

Horas disponibles, desplazamientos, licencias y otros costos necesarios.

4. Recursos para la Auditoría

La planificación debe comprobar que los recursos son suficientes para cubrir el alcance y obtener evidencia.

5. Cronograma de Auditoría

Actividad	Día / fecha	Duración	Responsable
Reunión de apertura	06/10	30 min	Auditor líder
Revisión documental	06–07/10	4 h	Auditor 1
Entrevistas	07/10	2 h	Auditor 2
Pruebas y análisis	08–09/10	5 h	Auditor 1 y 2
Cierre e informe preliminar	12/10	2 h	Auditor líder

Buenas prácticas

Secuenciar dependencias • Reservar tiempo para contingencias • No sobrecargar al mismo responsable • Considerar disponibilidad de evidencias

RESPONSABLES

Auditor líder

Coordina la auditoría, valida el programa, asigna tareas, supervisa avances y consolida resultados.

Auditores

Ejecutan procedimientos, obtienen evidencia, documentan resultados y comunican hallazgos.

Auditado / responsables

Facilitan acceso, explican procesos, entregan documentación y atienden solicitudes de evidencia.

6. Responsables

PROCEDIMIENTOS

- Son instrucciones concretas que indican cómo se obtendrá evidencia para responder a un objetivo.
- Deben especificar acción, población o muestra, fuente de evidencia y resultado esperado.
- Pueden combinar revisión documental, entrevistas, observación, pruebas y análisis de datos.
- Un procedimiento bien redactado permite que otro auditor comprenda y reproduzca el trabajo realizado.

7. Procedimientos de Auditoría

Ejemplo

Seleccionar 20 usuarios del ERP y comparar sus roles con la matriz de funciones aprobada.

Evidencia

Listado de usuarios + matriz de roles + muestra seleccionada.

Resultado

Conforme / excepción / pendiente de evidencia.

8. Técnicas de Auditoría

TÉCNICAS

Observación

Ver directamente cómo se ejecuta una actividad.

Entrevista

Obtener información mediante preguntas al personal.

Inspección

Examinar documentos, configuraciones, registros o activos.

Confirmación

Corroborar información con una fuente independiente.

Recalculo

Comprobar nuevamente un resultado o cálculo.

Análisis de datos

Buscar patrones, excepciones, duplicidades o tendencias.

¿Qué técnica conviene usar?

Objetivo	Técnica principal	Ejemplo de aplicación
Comprobar un procedimiento	Observación	Observar el proceso de alta de usuarios.
Conocer cómo se realiza una actividad	Entrevista	Preguntar quién autoriza los accesos.
Verificar documentos o configuraciones	Inspección	Revisar logs, políticas o parámetros.
Corroborar un dato	Confirmación	Validar una lista con el administrador.
Detectar patrones	Análisis de datos	Buscar accesos fuera de horario.

Una auditoría sólida suele combinar técnicas: ninguna técnica por sí sola responde todas las preguntas.

Evidencia: el puente entre procedimiento y conclusión

EVIDENCIA

Objetivo	Verificar que solo usuarios autorizados acceden al ERP.
Procedimiento	Revisar una muestra de usuarios y comparar roles con autorizaciones.
Técnicas	Inspección + análisis de datos + entrevista.
Evidencia	Matriz de roles, listado de usuarios, tickets de autorización y registros.
Conclusión	Se identifican conformidades, excepciones o ausencia de evidencia.

La evidencia debe permitir sustentar la conclusión y dejar trazabilidad del trabajo realizado.

Planificación con enfoque basado en riesgos

PRIORIZACIÓN

Probabilidad

Baja / media / alta

Impacto

Bajo / medio / alto

Riesgo

Probabilidad × impacto

Respuesta

Priorizar pruebas y recursos donde el riesgo sea mayor

Ejemplo Accesos privilegiados no revisados → alto riesgo → mayor profundidad de pruebas y mayor evidencia solicitada.

La priorización ayuda a usar mejor el tiempo sin perder de vista los objetivos y el alcance aprobados.

Estructura de un Programa de Auditoría

N.º	Objetivo	Procedimiento	Técnica	Evidencia	Responsable	Fecha
1	Verificar accesos	Comparar usuarios vs. matriz de roles	Inspección + análisis	Listado y matriz	Auditor 1	06/10
2	Evaluar respaldos	Revisar cumplimiento del plan de backup	Inspección + observación	Reportes de backup	Auditor 2	07/10
3	Revisar incidentes	Analizar muestra de tickets	Análisis + entrevista	Tickets y SLA	Auditor 1	08/10

Campos opcionales Criterio • Muestra • Estado • Referencia de papel de trabajo • Observaciones

Ejemplo de programa: Gestión de accesos al ERP

Paso	¿Qué hará el auditor?	Resultado esperado
1	Obtener listado de usuarios activos.	Población completa identificada.
2	Seleccionar una muestra según el criterio definido.	Muestra documentada.
3	Comparar rol asignado con matriz de funciones.	Coincidencias y excepciones.
4	Revisar evidencia de aprobación para excepciones.	Autorizaciones válidas o brechas.
5	Documentar conclusión y referenciar evidencias.	Conclusión sustentada.

Observa la cadena lógica: objetivo → procedimiento → evidencia → resultado → conclusión.

Del objetivo al procedimiento: ejemplo completo

Objetivo

Evaluar si los accesos al ERP están autorizados y corresponden a las funciones del usuario.

Criterio

Matriz de roles aprobada + procedimiento de altas, bajas y modificaciones de usuarios.

Procedimiento

Revisar población de usuarios, seleccionar muestra, comparar roles y validar autorizaciones asociadas.

Evidencia

Listado de usuarios + matriz + tickets/solicitudes + registro de excepciones.

CASO

- TECNOSOFT S.A.C. utiliza un ERP para ventas, compras, almacén y contabilidad.
- Durante los últimos meses se incorporaron nuevos usuarios y se reportaron cuentas con privilegios elevados.
- El área de TI mantiene respaldos diarios, pero no existe evidencia uniforme de revisión y pruebas de restauración.
- La gerencia solicita una auditoría informática para evaluar accesos, respaldos y gestión de incidentes.
- El equipo auditor dispone de 3 días efectivos y dos auditores.

ANÁLISIS

Objetivos

1. Evaluar la gestión de accesos.
2. Verificar el cumplimiento del plan de respaldos.
3. Revisar el registro y tratamiento de incidentes.

Alcance

ERP corporativo de la sede principal.
Usuarios, roles, respaldos e incidentes.
Periodo: enero–agosto 2026.

Criterios

Políticas internas.
Procedimientos aprobados.
Matriz de roles.
Plan de backups.
Registro de incidentes y acuerdos de servicio.

Caso: recursos, cronograma y responsables

Actividad	Responsable	Duración
Documentación y población de usuarios	Auditor 1	1/2 día
Respaldos y pruebas de restauración	Auditor 2	1/2 día
Incidentes y entrevistas	Ambos	1 día
Análisis, hallazgos y cierre	Auditor líder + equipo	1 día

Recursos clave

2 auditores • acceso al ERP • reportes • logs • tickets • políticas • almacenamiento seguro.

Control del cronograma

Apertura → obtención de evidencia → pruebas → análisis → cierre. Registrar avances y pendientes.

El cronograma debe ser realista: la disponibilidad de evidencia puede generar reprogramaciones.

Actividad práctica: construyan el Programa de Auditoría



TRABAJO EN EQUIPO

1. Formen equipos de 3–4 estudiantes.
2. Usen el caso TECNOSOFT y definan 3 objetivos.
3. Delimiten alcance y establezcan al menos 4 criterios.
4. Asignen recursos, responsables y un cronograma de 3 días.
5. Elaboren mínimo 6 procedimientos e indiquen técnica y evidencia.
6. Presenten su programa y justifiquen dos decisiones de planificación.

Producto: una matriz de programa de auditoría lista para ser utilizada como guía de ejecución.

Cierre: checklist del buen programa de auditoría

- ☐ Los objetivos están redactados con verbos observables.
- ☐ El alcance señala qué incluye, límites y periodo.
- ☐ Los criterios son claros y verificables.
- ☐ Los recursos y responsables están definidos.
- ☐ El cronograma es realista y coherente con el alcance.
- ☐ Cada procedimiento se relaciona con un objetivo.
- ☐ Cada procedimiento indica técnica y evidencia esperada.
- ☐ Existe trazabilidad desde el objetivo hasta la conclusión.

Pregunta de salida: ¿qué elemento del programa asegura que la auditoría no se vuelva improvisada?



... alguna pregunta?



REFERENCIA BIBLIOGRAFICA

- ✓ Piattini , M, Del Peso, E, & Del Peso, M. (2008). Auditoría de tecnologías y sistemas de información. RAMA. <https://www.alphaeditorialcloud.com/library/publication/auditoria-de-tecnologias-y-sistemas-de-informacion>
- ✓ COSO (2013). Internal Control – Integrated Framework.
- ✓ ISACA (2019). COBIT 2019 Framework.
- ✓ ISO/IEC 27001:2022. Seguridad de la información.



*Muchas
Gracias!*